COMPTIA SECURITY+ SY0-701 | DOMAIN 2 · THREATS, VULNERABILITIES, AND MITIGATIONS (22%)

Security+ 2.4 · Viruses & Worms

Mestre CyberSec · **Lesson 2.4 — Viruses & Worms** (5:54) · Assistir Vídeo no YouTube ↗ · Treino Interativo: edusouzamarques.github.io/cybersec

Executive Lesson Summary: Vírus PRECISA de hospedeiro (arquivo) e ação do usuário pra propagar. Worm SE-PROPAGA SOZINHO pela rede (sem hospedeiro). Fileless roda direto na RAM — não toca no disco. Defesa: patch (worm explora vulnerabilidade de rede), EDR com behavioural detection.

💡 Key Exam Highlights & Critical Concepts

- Vírus: precisa de hospedeiro + usuário. Worm: se-propaga sozinho
- Fileless: nenhum arquivo no disco — detectado pela memória/log, não hash

🎯 Exam Tips & Typical CompTIA Scenarios

- 'self-propagates through the network without user action' = worm

🚨 Beyond the Video: Official Exam Concepts, Protocols & Traps (Section 2.4 — Viruses & Worms)

Why is this advanced coverage required for SY0-701?: Video lectures provide foundational concepts, but CompTIA tests practical engineering judgment and requires deep familiarity with the following protocols, acronyms, and operational nuances in this domain:

• Virus (N/A)
Malicious code that attaches to a host file or executable and requires user action to replicate and spread.
⚠ ***Exam Trap:*** *Precisa de hospedeiro + ação do usuário. Se a questão enfatiza propagação sem interação, não é vírus.*

• Worm (N/A)
Self-replicating malware that spreads across networks without a host file or user action, often exploiting vulnerabilities.
⚠ ***Exam Trap:*** *Gatilho: 'self-propagates through the network without user action' = worm. Não precisa de hospedeiro.*

• Fileless Malware (N/A)
Malware that executes in memory and does not write a file to disk, making hash-based detection difficult.
⚠ ***Exam Trap:*** *Detecção via memória, logs e comportamento; não depende de hash de arquivo.*

• Endpoint Detection and Response (EDR)
Security solution that monitors endpoint activity and uses behavioral detection to identify and respond to malicious actions, including fileless attacks.
⚠ ***Exam Trap:*** *Defesa chave contra fileless e worms: comportamento, telemetria e resposta, não apenas assinaturas.*

• Patch Management (N/A)
Process of applying software updates to remediate vulnerabilities that worms commonly exploit for network propagation.
⚠ ***Exam Trap:*** *Defesa primária contra worms: corrigir a vulnerabilidade de rede explorada. Patch antes do ataque.*

• Self-Propagation (N/A)
Ability of malware to spread autonomously without user interaction, characteristic of worms.
⚠ ***Exam Trap:*** *Palavra-chave para worm. Vírus não se auto-propaga sem ação do usuário.*

• Host (N/A)
File, executable, or system component that a virus infects and uses to replicate and spread.

⚠️ ***Exam Trap:*** *Vírus PRECISA de hospedeiro; worm NÃO. Se a questão menciona arquivo infectado, pense em vírus.*

- **Payload (N/A)**

Malicious action or code delivered by malware, such as data destruction, encryption, or backdoor installation.

⚠️ ***Exam Trap:*** *Payload é o que o malware faz; propagação é como ele se espalha. Não confunda com o vetor.*

🏛️ Conceptual Deep Dive, Real-World Analogies & GRC Analysis

📌 Virus vs. Worm: Human Action and Network Self-Propagation

🏠 **Real-World Analogy:** A biological Virus requires a ride: it sits passively on a doorknob or handrail and cannot spread until a human touches the surface and rubs their eyes (it relies strictly on a host file and deliberate human action to execute and replicate). A Worm, in contrast, is an autonomous nocturnal predator with its own legs: it crawls down hotel hallways, discovers unlatched doors, and slithers into every bedroom on the floor without any resident having to invite it in or click anything.

🔍 **Root Cause & Background:** A virus is architecturally parasitic, binding malicious routines to existing executable containers (.exe, DLLs, Office macros) and executing only when that host file is launched. A worm is an autonomous standalone binary engineered for network protocols: it continuously scans address ranges for unpatched services (such as buffer overflows in SMB, RDP, or RPC) to replicate across machines without user intervention.

🛡️ **GRC Auditor Perspective:** Mitigating viruses requires user awareness campaigns, gateway email filtering of dangerous extensions, and enterprise group policy disabling untrusted macros. Mitigating worms demands aggressive Vulnerability Management SLAs for network-facing vulnerabilities (CVSS 9.0+) combined with Zero Trust microsegmentation (blocking lateral SMB 445 and RDP 3389 communication between endpoint workstations).

⚠️ **How CompTIA Tests This:** Trigger: 'malware attaches itself to an executable host file and requires user intervention to launch and spread'. Answer: Virus. Trigger: 'malware self-replicates across the network automatically by exploiting network services without user intervention'. Answer: Worm.

📌 Boot Sector Virus and MBR Exploitation

🏠 **Real-World Analogy:** Imagine a high-security office building. The boot sector is the dawn security guard who arrives at 5:00 AM before all staff, turns on the generators, unlocks perimeter gates, and verifies who enters. A boot sector virus ambushes that dawn guard and takes his seat. When the chief security officer (the antivirus and OS) arrives at 8:00 AM, the virus already holds absolute administrative control: it alters operating procedures and blinds internal monitors before security software even awakens.

🔍 **Root Cause & Background:** Legacy computing architectures (BIOS and Master Boot Record - MBR) unconditionally execute instructions located in the first 512 bytes of a storage drive during POST hardware initialization. Boot sector malware overwrites or hooks this pointer, seizing execution control before the OS kernel, memory integrity protections, and antivirus kernel drivers are initialized.

🛡️ **GRC Auditor Perspective:** Mandate UEFI with Secure Boot permanently enabled across all enterprise workstations and servers, integrated with hardware Trusted Platform Modules (TPM 2.0). Secure Boot cryptographically validates bootloader signatures against embedded OEM certificates, instantly halting execution if the boot sector or startup chain has been tampered with.

⚠️ **How CompTIA Tests This:** Trigger: 'malware that infects the Master Boot Record (MBR) or storage boot sector, executing prior to operating system initialization to hide from antivirus'. Answer: Boot Sector Virus. Primary CompTIA mitigation: UEFI Secure Boot.

📌 Memory-Resident and Fileless Malware

🏠 **Real-World Analogy:** Imagine a bank burglar who brings no suspicious crowbars and hides no stolen gear in company lockers. They walk in as an ordinary customer and instruct the building's legitimate maintenance staff (native system tools like PowerShell or WMI) to unlock the vaults using standard master keys. If forensic police inspect the lockers and physical files (the hard drive), they find zero malicious files. Furthermore, if power is cut to the facility (a system reboot), the burglar's live state in volatile memory vanishes without leaving persistent footprints.

🔍 **Root Cause & Background:** Traditional antivirus engines primarily scan persistent files written to disk storage. To bypass this, fileless malware embraces 'Living off the Land' (LotL) techniques: it injects malicious instructions directly into the volatile RAM space of trusted operating system processes (such as svchost.exe or powershell.exe) via script stubs or compromised document memory buffers, never depositing a persistent binary file onto the disk.

🛡️ **GRC Auditor Perspective:** Audit the operational hardening of script interpreters (enforcing PowerShell Constrained Language Mode via AppLocker/WDAC), mandate Script Block Logging (Event ID 4104), and deploy modern EDR agents equipped to inspect API hooking and process memory injection in volatile RAM.

⚠️ **How CompTIA Tests This:** Trigger: 'malware operates entirely in volatile RAM, writes no files to persistent disk, and leverages native administrative binaries like PowerShell or WMI'. Answer: Fileless malware / Memory-resident malware. Distractor alert: Rebooting clears the volatile RAM footprint, but persistent scheduled triggers or WMI subscriptions will reinfect upon startup.

📌 Historical Parallels: Stuxnet (Industrial Sabotage) vs. WannaCry (Ransomware Worm)

🏠 **Real-World Analogy:** WannaCry was an uncontrolled wildfire: discovering that thousands of suburban homes left their ground-floor windows unlatched (unpatched SMB port 445), it roared across global networks in hours, encrypting hospitals and enterprises indiscriminately to collect ransom payments. Stuxnet was a precision-guided military stealth drone: engineered by nation-states to leap across air-gapped networks via USB thumb drives, it ignored ordinary workstations, navigating undetected until it reached industrial SCADA centrifuges in a specific nuclear enrichment facility, physically spinning them to mechanical destruction while reporting normal metrics to engineers.

🔍 **Root Cause & Background:** WannaCry weaponized the leaked nation-state exploit EternalBlue (vulnerabilities in SMBv1) with a mass-market ransomware payload, enabling self-propagation across exposed lateral networks. Stuxnet represented an APT state-sponsored cyberweapon that chained four zero-day vulnerabilities, stolen digital driver certificates, and direct Siemens PLC/SCADA commands to destroy industrial hardware.

🛡️ **GRC Auditor Perspective:** Mitigating WannaCry-style outbreaks requires deprecating legacy protocols (globally disabling SMBv1), emergency patch deployments, and blocking sharing ports at network boundaries. Mitigating Stuxnet-level industrial sabotage mandates strict physical USB port locking in Operational Technology (OT/ICS), unidirectional data diodes for air-gapped enclaves, and firmware integrity verification on PLCs.

⚠️ **How CompTIA Tests This:** Trigger: 'ransomware incident that propagated autonomously across internal networks without user action by exploiting an SMB vulnerability'. Answer: WannaCry (Worm-delivered Ransomware). Trigger: 'sophisticated malware targeting industrial programmable logic controllers (PLCs/SCADA) traversing air-gapped systems via removable media'. Answer: Stuxnet.

⚡ QUICK-REFERENCE EXAM CHEAT SHEET

Typical Exam Scenario / Practical Situation	Technical Concept & Target Answer
Malicious code attaching to an executable host file requiring user interaction to execute and spread	**Virus (host file dependency and human action)**
Standalone program self-replicating across networks by exploiting unpatched services without human intervention	**Worm (network standalone self-replicator)**
Malware corrupting the Master Boot Record to execute before OS startup and hide from antivirus software	**Boot Sector Virus (mitigated by UEFI Secure Boot)**
Malware executing via PowerShell by injecting code directly into RAM without saving executable files to disk	**Fileless / Memory-Resident Malware**
Global outbreak that crippled enterprise and hospital networks combining the SMB EternalBlue exploit with ransomware	**WannaCry (classic network worm ransomware)**
State-sponsored cyberweapon designed to breach air-gapped networks via removable media to sabotage SCADA/ICS PLCs	**Stuxnet (targeted industrial control attack)**

✅ Authentic Practice Questions (10 Real Exam Scenarios)

Scenario-based exam questions. Complete explanations and distractor analysis are provided in the answer key below.

QUESTION 1 · EXAM SCENARIO

A finance employee opens a spreadsheet attached to a supplier email. The spreadsheet contains a macro that copies itself into the user's normal template and infects other .xlsx files the employee later edits. It does not spread to other computers unless those infected files are opened there. Which malware type best fits this behavior?

A) Virus

B) Worm

C) Fileless malware

D) Rootkit

QUESTION 2 · EXAM SCENARIO

A hospital network has several unpatched Windows servers. A malicious program scans TCP 445, exploits SMB, copies itself to every reachable server, and continues scanning from each newly infected host. No user opens a file or clicks a link. Which type is it?

A) Virus

B) Worm

C) Fileless malware

D) Trojan

QUESTION 3 · EXAM SCENARIO

During incident response, an analyst finds that a phishing document launched PowerShell, which injected code into a running process and executed commands only in memory. No malicious executable was written to disk, and the activity disappeared after reboot. Which malware technique is described?

A) Fileless malware

B) Worm

C) Boot sector virus

D) Multipartite virus

QUESTION 4 · EXAM SCENARIO

A vendor releases a critical patch for a remote code execution flaw in a network service. Until the patch is applied, a worm can compromise any reachable unpatched server without user interaction. Which control most directly reduces the risk of this worm's initial spread?

A) Patch management

B) Email attachment filtering

C) Security awareness training

D) Full disk encryption

QUESTION 5 · EXAM SCENARIO

A SOC wants to detect attacks that use PowerShell, WMI, and process injection, leave no files on disk, and behave differently from known signatures. Which technology is best suited for this detection?

A) Signature-based antivirus

B) EDR with behavioral detection

C) Data loss prevention

D) Full disk encryption

QUESTION 6 · EXAM SCENARIO

A portable malware sample copies itself to USB drives and mapped network shares. However, it only executes when a user double-clicks an infected file, and it does not exploit any network service to spread by itself. Which type is most likely?

A) Worm

B) Virus

C) Fileless malware

D) Ransomware

QUESTION 7 · EXAM SCENARIO

A malware outbreak encrypts files on many servers. Forensic analysis shows the initial component exploited a web server vulnerability, scanned the internal network, and copied itself to other hosts. After spreading, it downloaded a ransomware payload. What is the self-propagating component called?

A) Virus

B) Worm

C) Fileless malware

D) Adware

QUESTION 8 · EXAM SCENARIO

A malware analyst examines a sample that attaches its code to a legitimate application executable. The application still runs, but when an unsuspecting user launches it, the malware executes and infects other executables on the same system. Which malware classification matches this sample?

A) Virus

B) Worm

C) Fileless malware

D) Spyware

QUESTION 9 · EXAM SCENARIO

A company wants to reduce the risk of macro viruses delivered through documents. Users frequently receive Office files from external partners. Which control is most effective for preventing the macro from executing when a user opens a document?

A) Disable macros by default and allow only signed macros from trusted publishers

B) Install full disk encryption on all laptops

C) Block all outbound DNS traffic

D) Enable port security on access switches

QUESTION 10 · EXAM SCENARIO

An incident response team confirms that a worm exploited an unpatched service and then installed a cryptocurrency miner on each infected host. Which term best describes the cryptocurrency miner in this infection chain?

A) Payload

B) Host

C) Worm

D) Fileless malware

ANSWER KEY & COMPREHENSIVE DISTRACTOR EXPLANATIONS

Question 1: Option A — Virus

This is a virus because it requires a host file (the spreadsheet/template) and user action (opening/editing the file) to propagate. It does not self-propagate over the network like a worm. Fileless malware would execute in memory without dropping a file, and a rootkit is focused on stealth/persistence, not this propagation pattern.

Question 2: Option B — Worm

This is a worm because it self-propagates across the network by exploiting a service vulnerability, without needing a host file or user action. A virus needs user execution and a host file; fileless malware runs in memory but does not inherently self-propagate; a Trojan disguises itself as legitimate software and does not automatically spread this way.

Question 3: Option A — Fileless malware

This is fileless malware because the malicious code runs in RAM and does not write a persistent executable to disk. Worms self-propagate over networks, while boot sector and multipartite viruses involve disk or boot-record infection and file-based propagation.

Question 4: Option A — Patch management

Patch management most directly closes the network service vulnerability that the worm exploits. Email filtering and awareness training help against user-driven threats like viruses, and full disk encryption protects data at rest but does not stop remote exploitation.

Question 5: Option B — EDR with behavioral detection

EDR with behavioral detection is best because it monitors process behavior, memory activity, and command-line execution, which can reveal fileless attacks even when no malicious file is written. Signature-based antivirus may miss novel or memory-only behavior; DLP and disk encryption do not detect process injection or PowerShell abuse.

Question 6: Option B — Virus

This is most likely a virus because it spreads through files and requires user action to execute. Although it reaches USB drives and network shares, it does not self-propagate by exploiting network services, which is the defining behavior of a worm. Fileless malware would not rely on infected files, and ransomware describes a payload/impact, not the propagation method.

Question 7: Option B — Worm

The self-propagating component is a worm because it spreads across the network by exploiting a vulnerability and does not need a host file or user action. Ransomware is the payload delivered after propagation. A virus would require user execution and a host file, and fileless malware is defined by memory-only execution, not self-propagation.

Question 8: Option A — Virus

This matches a virus because it uses a legitimate executable as a host, modifies it, and relies on the user launching the infected program to execute and spread to other files. A worm would spread without user action or a host file, fileless malware would avoid disk files, and spyware describes a data-collection payload rather than this infection method.

Question 9: Option A — Disable macros by default and allow only signed macros from trusted publishers

Disabling macros by default and allowing only signed macros directly prevents untrusted macro code from executing when a document is opened, which blocks the virus's infection routine. Disk encryption, DNS blocking, and switch port security do not address document macro execution.

Question 10: Option A — Payload

The cryptocurrency miner is the payload because it is the malicious action or code delivered after the worm gains access and spreads. The host is the infected system or the file that carries a virus, the worm is the self-propagating mechanism, and fileless malware is not indicated by the scenario.